Tabletop Report

Tabletop Simulation

Honest Reflections & Lessons Learned

Document Title	Post-Exercise Review & Lessons Learned: Q1 2026 Tabletop
Classification	Public For Educational Purposes
Date of Issue	15 April 2026
Author	Chris Ejike, CISSP | Simulation Lead

Preface

A tabletop exercise is only valuable if it exposes gaps before a real attacker does. While the team successfully contained the simulated threat, the exercise highlighted several areas where our incident response maturity needs to improve. Here are the key takeaways and challenges we identified.

1. Prioritisation Under Pressure is Harder Than It Looks

When the scenario first dropped, the team's instinct was to treat both systems—the external-facing and the internal-facing—with equal urgency. It took deliberate intervention to redirect focus toward the internal system first. In a real incident, that delay in prioritisation could cost valuable time. The lesson here is that the team needs a pre-agreed triage framework before the pressure hits, not during it.

2. Cross-Functional Communication Gaps

Not everyone speaks the same language during an incident. The SIEM analyst was thinking in log data, the developer was thinking in application behaviour, and the server administrator was thinking in ports and services. All three were right, but they were not talking to each other effectively. One of the most valuable outcomes of this exercise was identifying that cross-functional communication needs to be practised, not assumed.

3. Firewall Rules Are Often Set and Forgotten

During the exercise, the question of why the firewall was allowing external traffic through to an internal-facing system surfaced an uncomfortable truth: nobody could immediately answer it. Rules accumulate over time, and without regular review, they become a liability. This challenge exposed a real gap in our infrastructure governance, not just a hypothetical one.

4. Rate Limiting is a Reaction, Not a Strategy

The server administrator's first response was to apply rate limiting to slow down the scanning activity. That was a reasonable immediate action, but the team initially stopped there. The deeper question of *why* the traffic was reaching the server at all was almost missed. Good incident response means asking the next question, not just treating the symptom.

5. Assumptions About Tool Visibility Were Wrong

There was an assumption going in that Wazuh would surface everything the team needed. In practice, the exercise revealed gaps in what was being logged and monitored, particularly around lateral movement indicators on the internal system. You cannot investigate what you cannot see.

6. Blocking an IP is Not the Same as Containing a Threat

The team moved quickly to block the suspicious IP, which was the right call. However, the discussion that followed revealed that nobody had considered whether the attacker might already be inside, or whether the IP was being spoofed. Blocking the front door is not enough if the window is already open.

7. The Exercise Itself Was Underestimated

Honest reflection: the first 10 minutes of the exercise were slower than they should have been. Participants were not fully in the mindset of treating it as a real event. This is a facilitation challenge as much as a team readiness challenge. Future exercises will open with a more immersive scenario briefing to close that gap faster.